

1. Description of TCP Normal Behaviour

Provide information sourced from the capture file that demonstrates your understanding of TCP handshaking concepts.

TCP (Transmission Control Protocol) is an internet protocol, known for providing a reliable and error-checked method of data delivery across a network. Sharma (2024) describes TCP communication in three main stages.

1. Connection establishment

A three-way handshake is used to establish a connection between the client and the server.

2. Data transfer

Data is broken up into smaller segments and transmitted over the network. Each segment contains a sequence number and acknowledgement value.

3. Connection termination

Finally, when the data transfer is complete, a four-way handshake is used to close the connection.

Normal TCP Traffic in Capture File

The capture file clearly shows examples of normal TCP traffic:

Packet 1 (SYN): Client 192.168.40.40 initiates connection to server 192.168.30.30 with SYN flag set, Seq=0.

Packet 2 (SYN-ACK): Server 192.168.30.30 replies to client 192.168.40.40 with SYN and ACK flags, Seq=0, Ack=1.

Packet 3 (ACK): Client 192.168.40.40 confirms with server 192.168.30.30 with ACK flag and establishes connection.

This sequence is a three-way handshake between Gail (192.168.40.40) and the HTTP server (192.168.30.30). Following the handshake is "GET /power.csv HTTP/1.1 200 OK", which confirms it is an HTTP request. Sessions also end with FIN/ACK exchanges, showing that TCP is functioning correctly.

2. Identification of Abnormal TCP traffic

Provide information sourced from the capture file that shows where TCP anomalies exist.

Analysis of the network capture reveals multiple TCP abnormalities starting with line 31. FIN and SYN packets data segments consistently contain 1024 bytes of repeating ASCII symbols, violating normal TCP behaviour where SYN packets should have zero payload and FIN packets typically signal closure without application data.

The traffic indicates an attack, with the more likely types are:

FIN Flooding – The server is flooded with FIN packets via spoofed IP address to force a server to try to close connections which do not exist, thus exhausting server's resources. The attack starts from line 31 and comes from IP 192.168.30.10. This appears to be a DoS attack.

Stealth SYN Scan – Attacker sends SYN requests across ports of server. If the server responds with SYN/ACK, the attacker understands that this port is active and can be exploited. To avoid detection, the attacker terminates the connection with the RST packet, giving SYN → SYN/ACK → RST sequence instead of a regular 3-way handshake. This attack starts at line 51 and comes from IP 192.168.40.50. This may also be an attacker's way of checking if the server is down.

3. Outline of Mitigation Strategy

Provide suggestion on mitigation strategies that might reduce the likelihood of such attacks occurring on this network.

Network Segmentation and Access Control: Apply strict firewall rules between the workstation (192.168.40.50) and server (192.168.30.30) segments to block lateral movement. This limits access to critical components like the HTTP server. Firewalls should block abnormal packets, like SYN packets with large payloads, and enforce proper TCP handshakes. However, segmentation can be complex to design and maintain in large OT networks.

Intrusion Detection and Prevention Systems: Deploy IDPS to detect abnormal traffic, including SYN packets with 1024 bytes of ASCII data and rapid connection attempts. These systems block attacks in real time. They may, however, slow network performance if heavily used.

Rate Limiting and SYN Flood Protection: Use rate limiting and SYN cookies to reduce automated flooding. Aggressive limits, though, can sometimes block legitimate high-volume traffic.

4. Articulation of Service Level Agreement (SLA)

Provide suggested SLA criteria to be put in place between the OT team and the IT department.

Availability Standards: Network monitoring and security services must provide 99.9% uptime with penalties for non-approved downtimes lasting over 30 minutes. A monthly maintenance downtime of 4 hours is permitted.

Incident Response Time: The IT department must respond to a critical security incident within 20 minutes and must resolve the issue within 2 hours. Medium and Low-Level incidents must be resolved within 5 hours. There must also be 24/7 support by email/chat even after business hours.

Reports: Continuous network health monitoring and vulnerability scans must be provided, with security reports to be delivered every fortnight by the department. A Quarterly vulnerability assessment must be conducted throughout the OT systems.

5. References

List any references in this section.

- P. Cichonski, T. Millar, T. Grance, and K. Scarfone, *Computer Security Incident Handling Guide*, NIST Special Publication 800-61, Revision 2, Aug. 2012.
- Sharma, H. (2024). *How does TCP Work? Workings and Structure of TCP Explained*. <https://www.uninets.com/UniNets>; UniNets. <https://www.uninets.com/blog/how-does-tcp-work>